

Detection logic

The detection logic varied depending on the complexity of each step in the attack scenario. Simpler steps were identified by a process creation and command keywords. In contrast, more complex procedures required the correlation of multiple indicators. For instance, Staging Monkey PNG search includes identifiers such as Copy command, .png extension and System.Drawing keyword. This combination suggests an image download and data decoding, which may indicate the use of steganography tools.

Another complex case involves the UAC Bypass via backup utility procedure. An SPL required correlating for the presence of HKCU in a command to match a registry key creation, a .exe reference suggesting execution of a utility and the PowerShell keyword indicating a shell being spawned. To reduce false positives, a regex exclusion was applied to filter out benign powershell.exe usage.

In another complex example, the Process Injection step was detected by matching multiple indicators, including Import-module, tobase64string, Start-Job and IP address regex pattern. These signals denote script loading, obfuscation with base64 encoding, background process launch and a network connection, respectively. Taken together, this points out a possible process injection.

Where applicable, the aim was to trace a technique that may employ varied tools rather than match a specific program. For instance, in detecting the Planting Modified SysInternalsSuite step the logic was focused on the actions of downloading a legitimate utility and copying malicious files to its folder. To elaborate, instead of searching for the SysInternalsSuite keyword, detection was based on the Invoke-WebRequest command and its aliases and the Copy-Item instruction.

In line with the approach of capturing general behaviour patterns, in the Automated Collection step, the SPL query matched three distinct file extensions to identify patterns of bulk document collection. In another example, detection of the Loading Stage-2 & Performing Discovery step focuses on file renaming activity. Specifically, it identifies files with a .txt, .log, .csv, .mp, .dat, .bak or .old extension being renamed to .ps1 in conjunction with the execution of a PowerShell script. Common command aliases such as Move-Item, mv, move and ren were included in the SPL query to provide comprehensive coverage.

To avoid false positives, searches capture patterns distinct to a procedure. For instance, detection of the Credential Dumping using Process Injection step is based on of loading a

script, invoking a function and performing unauthorised access to lsass.exe. This is achieved through matching a download-related command, such as iwr, wget, curl, webclient, downloadstring, downloadfile, an invoke-expression or iex instruction and the lsadump::sam string. In another example, to identify the lateral movement action, the SPL query tracks an IP address regex pattern alongside file transfer commands, .exe execution and PSexec keyword.